

DATA PROTECTION IMPACT ASSESSMENT (DPIA)
ShopEasy India — Third-Party Vendor Data Sharing

Organization: ShopEasy India Pvt. Ltd.

Prepared by: Privacy Compliance Team

Date: June 2026

Classification: Confidential

1. PROCESSING DESCRIPTION

Processing Activity:

ShopEasy India shares customer transaction data including name, email, purchase category, and location with third-party analytics vendors for behavioral profiling and targeted marketing purposes.

Data Categories:

- Personal identifiers (name, email, phone)
- Transaction data (amount, date, category)
- Location data (city)
- Behavioral data (purchase patterns)

Data Subjects: 10,000+ registered customers

Data Fiduciary: ShopEasy India Pvt. Ltd.

Third Party Processors: External analytics vendors

Legal Basis (GDPR Art. 6): Consent

Legal Basis (DPDP Act S.6): Consent of Data Principal

2. NECESSITY & PROPORTIONALITY

Is processing necessary for the stated purpose?

Partially. Behavioral profiling for marketing can be achieved with pseudonymized or aggregated data.

Sharing raw personal identifiers with vendors is NOT proportionate to the marketing objective.

Could a less privacy-invasive method achieve the same result?

YES — anonymized purchase category data is sufficient for trend analysis. Personal identifiers are excessive.

Proportionality Assessment: FAILS proportionality test.

Recommendation: Apply pseudonymization before vendor data transfer.

3. RISKS IDENTIFIED

Risk 1 — Unauthorized Secondary Use (HIGH)

Vendor may use personal data beyond agreed purpose.

Likelihood: High | Impact: High

Relevant: GDPR Art.5(1)(b) | DPDP S.6

Risk 2 — Consent Violation (HIGH)

214 records show vendor_shared=True with
consent_given=False — direct regulatory breach.

Likelihood: Confirmed | Impact: High

Relevant: GDPR Art.6 | DPDP S.6

Penalty exposure: Up to ₹250 crore (DPDP Act)

Risk 3 — Data Breach at Vendor (MEDIUM)

Vendor security posture unverified. Personal data
at risk if vendor systems are compromised.

Likelihood: Medium | Impact: High

Relevant: GDPR Art.32 | DPDP S.8

4. MITIGATION MEASURES

Measure 1 — Pseudonymization

Replace personal identifiers with tokens before vendor transfer. Vendor receives no raw PII.

Addresses: Risk 1, Risk 3

GDPR Principle: Data Minimisation (Art.5(1)(c))

Measure 2 — Consent Remediation

Immediately halt data sharing for all 214 records where consent_given=False. Obtain fresh explicit consent before resuming.

Addresses: Risk 2

Timeline: Immediate — within 7 days

Measure 3 — Data Processing Agreement (DPA)

Execute signed DPA with all vendors specifying:

- Permitted processing purposes
- Data retention limits (max 90 days)
- Security requirements
- Breach notification within 72 hours

Addresses: Risk 1, Risk 3

Relevant: GDPR Art.28 | DPDP S.8

5. RESIDUAL RISK ASSESSMENT

Before Mitigation: HIGH

After Mitigation: MEDIUM-LOW

Residual risks acceptable subject to:

- Quarterly vendor audit
 - Annual DPIA review
 - Continuous consent monitoring via PrivacyGuard
-

6. DPO SIGN-OFF

Data Protection Officer: [Name]

Review Date: June 2026

Decision: APPROVED WITH CONDITIONS

Next Review: December 2026

Signature: _____